

PHISHGUARD

Plateforme Web Intelligente de Détection, d'Analyse et de Suivi des Cybermenaces

Document : Cahier de Conception et de Réalisation Technique Complet (Architecture & Code)

Version : 1.0 (Version de travail — Production Ready)

Choix d'Architecture recommandé : Application Web full-stack (React + FastAPI + PostgreSQL + Scikit-Learn)

Chaîne Globale du Système : Détecter → Analyser → Classifier → Expliquer → Surveiller → Conserver les Preuves
→ Signaler → Vérifier → Conseiller

Raison d'être du Choix Web : Le choix d'une application Web s'impose comme l'architecture optimale pour PhishGuard. Elle permet de concilier la complexité des tableaux de bord d'analyse de menaces, la gestion centralisée des preuves numériques, la visualisation d'événements de sécurité en temps réel et le portail de vérification dédié aux enquêteurs. Ce document constitue la spécification exhaustive indispensable au développement, à la validation et à la maintenance du projet devant le jury.

Sommaire Exécutif du Cahier des Charges :

1. Vision et Objectifs du Projet
2. Définitions Essentielles & Glossaire
3. Architecture des Modules Fonctionnels
4. Analyse Approfondie d'une URL
5. Analyse des Messages et Emails
6. Surveillance de Site Web & Détection WAF/Logs
7. Cas Fil Conducteur (Attaque Brute Force)
8. Localisation IP & Limites
9. Incidents & Portail Enquêteur
10. Rôles et Droits (RBAC)
11. Stack Technique & Architecture
12. Modèle Logique de Données (MLD)
13. Sécurité de PhishGuard
14. Assistant Cybersécurité (IA)
15. Structure Web (Sitemap UI)
16. Use Cases
17. Entraînement ML
18. Pipeline Global
19. Livrables à Développer
20. Priorités MVP
21. Plan de Réalisation
22. Démonstration Jury
23. Défense Jury
24. Périmètre Non Couvert
25. Checklist

1. Vision et Objectifs du Projet PhishGuard

PhishGuard dépasse la simple notion de détecteur de phishing passif. Il s'agit d'une **plateforme web intégrée de Threat Intelligence, de détection d'attaques et de gestion des incidents de sécurité**. Le système est conçu pour répondre aux besoins opérationnels des utilisateurs (analyse directe d'éléments suspects) et des professionnels de la cybersécurité / enquêteurs (traçabilité, preuves numériques infalsifiables et rapports vérifiables).

Le système prend en charge la chaîne de traitement globale des cybermenaces :

- **Détecter** : Identifier la présence d'anomalies ou de caractéristiques suspectes dans les URLs, contenus et logs.
- **Analyser** : Extraire les variables techniques, examiner la réputation du domaine et classifier avec le Machine Learning.
- **Classifier** : Catégoriser précisément la menace (Phishing, SQLi, XSS, Brute Force, Scanning, Path Traversal, Bot).
- **Expliquer** : Fournir des justifications claires et compréhensibles par l'humain via des modèles d'IA explicable.
- **Surveiller** : Ingérer et analyser les flux d'événements de sécurité d'un site autorisé (logs WAF / serveur HTTP).
- **Conservier** : Sceller les preuves numériques avec des empreintes cryptographiques (Hash SHA-256) et horodatage.
- **Signaler** : Créer des incidents de sécurité structurés et exporter des rapports d'investigation officiels.
- **Vérifier** : Permettre à un enquêteur de contrôler l'authenticité et l'intégrité de l'analyse originale via un portail dédié.
- **Conseiller** : Délivrer des recommandations défensives et correctives contextualisées via un assistant IA d'aide à la décision.

2. Définitions Essentielles et Glossaire Technique

Terme	Définition Technique et Rôle dans PhishGuard
Phishing	Technique d'ingénierie sociale visant à tromper une victime pour lui dérober des identifiants, données bancaires ou installer un logiciel malveillant via des vecteurs imitant des entités légitimes (URL, Email, SMS).
Cybermenace	Tout événement, vecteur ou entité susceptible de compromettre la confidentialité, l'intégrité ou la disponibilité d'un système d'information.
Machine Learning	Branche de l'IA basée sur des algorithmes (ex: Random Forest) apprenant des motifs statistiques sur un jeu de données étiqueté afin de prédire la légitimité d'une menace.
Intelligence Artificielle	Ensemble des modules d'analyse, d'explication du risque et d'assistance conversationnelle défensive intégrés à la plateforme.
API (REST)	Interface logicielle standardisée (FastAPI) permettant l'interconnexion entre le Frontend, les moteurs ML/règles, la base de données et les services tiers.
Threat Intelligence	Données externes de réputation et d'indicateurs de compromission (IoC) issues de services spécialisés (VirusTotal, Google Safe Browsing).
Événement de Sécurité	Enregistrement individuel d'une activité réseau ou applicative (requête HTTP, tentative d'authentification, statut de réponse).
Incident de Sécurité	Regroupement d'événements suspects atteignant un seuil de gravité nécessitant une investigation et un suivi opérationnel.
Preuve Numérique	Donnée brute conservée (en-têtes HTTP, logs, corps de requête, horodatage, IP) garantissant la traçabilité de la détection.
Hash (SHA-256)	Empreinte cryptographique à sens unique garantissant l'immuabilité et l'intégrité des rapports et analyses enregistrés.
WAF / Reverse Proxy	Pare-feu applicatif ou serveur intermédiaire filtrant et transmettant les événements d'un site web autorisé vers PhishGuard.
Géolocalisation IP	Estimation de l'emplacement réseau d'une adresse IP (Pays, ISP, ASN). Ne constitue pas une preuve de la localisation physique de l'attaquant.

3. Architecture des Modules Fonctionnels

PhishGuard s'articule autour de 6 modules fonctionnels majeurs interconnectés :

Module	Fonctions Clés et Description Operationnelle
1. Analyse de Menaces	Analyse multi-vecteurs (URL, Message SMS/Chat, Email). Extraction automatique des caractéristiques, exécution du modèle ML, corrélation par moteur de règles, interrogation des APIs Threat Intelligence et génération du score de risque.
2. Surveillance de Site Web	Ingestion d'événements de sécurité en provenance d'un site autorisé (logs HTTP, tentative d'accès, WAF). Normalisation et détection automatique des attaques (SQLi, XSS, Brute Force, Scanning, Path Traversal, Bots).
3. Gestion des Incidents	Création automatique ou manuelle d'incidents de sécurité qualifiés (LOW, MEDIUM, HIGH, CRITICAL). Agrégation des preuves numériques, attribution d'IDs uniques (INC-2026-XXXX) et gestion du cycle de vie (Ouvert, En cours, Résolu).
4. Portail Enquêteur & Vérification	Interface réservée aux agents habilités. Recherche de rapports par Report ID / Code, récupération de l'analyse originale non modifiable en base, contrôle d'intégrité par Hash SHA-256 et validation de l'enquête.
5. Assistant Cybersécurité IA	Chatbot défensif contextualisé basé sur LLM. Explique le verdict des détections et fournit des guides de remediation pas-à-pas adaptés aux vulnérabilités identifiées.
6. Administration & Governance	Gestion des utilisateurs et rôles (RBAC), configuration des clés d'APIs externes, surveillance de la santé du système et traçabilité globale (Audit Trail).

4. Analyse Approfondie d'une URL (ML & Threat Intelligence)

Workflow Technique de Traitement d'une URL :

Utilisateur → Saisie URL → Backend FastAPI (Validation & Sanitization) → Extracteur de Caractéristiques → Prédiction Random Forest + Moteur de Règles → Interrogation APIs Threat Intel (VirusTotal / Google Safe Browsing) → Calcul du Score de Risque Global → Génération Explication IA → Sauvegarde DB & Historique

Caractéristiques Techniques Extraites de l'URL :

- **Caractéristiques Lexicales** : Longueur totale de l'URL, nombre de points, tirets, sous-domaines, présence de caractères normés suspect (@, %, double slash //).
- **Signaux d'Hôte & Réseau** : Présence d'une adresse IP directe (IPv4/IPv6) à la place du nom de domaine, analyse de l'utilisation d'un port non standard (ex: :8080, :8888).
- **Certificat SSL/TLS & HTTPS** : Vérification du protocole (HTTPS vs HTTP), validité du certificat SSL, émetteur et durée de validité du domaine.
- **Mots-Clés de Hameçonnage** : Présence de mots-clés à haut risque dans l'URL (ex: *login, verify, account, update, banking, paypal, secure, signin*).
- **Analyse des Redirections** : Détection des raccourcisseurs d'URL (bit.ly, tinyurl) et suivi des chaînes de redirections HTTP jusqu'à la destination finale.
- **Indicateurs Domain & WHOIS** : Âge du nom de domaine, date de création récente (< 30 jours = risque élevé), masquage WHOIS anonyme.

Algorithme de Machine Learning — Random Forest Classifieur :

Pour la version 1.0, l'algorithme **Random Forest** est sélectionné pour des raisons d'efficacité éprouvée :

- **Gestion d'attributs hétérogènes** : Combine parfaitement des variables numériques (longueurs, comptes) et catégorielles (booléens SSL, présence d'IP).
- **Résistance au surapprentissage (Overfitting)** : L'agrégation d'arbres de décision multiples garantit une excellente généralisation.
- **Explicabilité (Feature Importance)** : Permet d'extraire les poids des caractéristiques les plus déterminantes dans la classification pour alimenter l'assistant IA.
- **Métriques d'évaluation requises** : Accuracy ($\geq 95\%$), Precision ($\geq 94\%$), Recall ($\geq 93\%$), F1-Score ($\geq 94\%$) et validation par Matrice de Confusion.

5. Analyse des Messages (SMS/Social) et des Emails

5.1. Analyse des Messages / SMS

L'utilisateur soumet le texte d'un message suspect (SMS, WhatsApp, message réseau social). Le backend applique une analyse sémantique et lexicale combinée :

- **Extraction automatique des URLs** : Identification et isolation des liens contenus dans le texte pour analyse par le module URL.
- **Détection d'urgence artificielle** : Recherche de formules coercitives (ex: "*Compte bloqué sous 24h*", "*Action immédiate requise*", "*Dernier avertissement*").
- **Démarchage et demandes financières** : Détection des appels au virement, demande de codes OTP ou de cartes cadeaux.
- **Usurpation d'identité (Impersonation)** : Détection d'imitation de banques, administrations (Impôts, Ameli) ou services de livraison (Chronopost, Colissimo).

5.2. Analyse des Emails Suspects

Pour le MVP, l'email peut être analysé via le copier-coller du corps/en-têtes ou le dépôt d'un fichier .eml ou .msg :

- **Analyse des en-têtes (Headers)** : Vérification de la cohérence entre l'adresse expéditeur apparente (From:) et l'adresse réelle de retour (Reply-To: / Return-Path:).
- **Protocoles d'Authentification Email** : Analyse des résultats SPF (Sender Policy Framework), DKIM (DomainKeys Identified Mail) et DMARC.
- **Analyse des liens et pièces jointes** : Vérification de toutes les URLs intégrées et analyse de la dangerosité des extensions de fichiers joints (ex: .exe, .scr, .iso, .vbs, .xlsm).

6. Surveillance de Site Web & Détection d'Attaques sur Site Autorisé

Point Essentiel d'Architecture : Une simple URL externe ne permet pas de connaître les attaques visant un site. Pour assurer cette fonction, PhishGuard reçoit des événements/logs envoyés par un site autorisé (via API, agent WAF, reverse proxy ou environnement de test sécurisé).

Flux d'Ingestion des Logs et Événements de Sécurité :

Site Autorisé (Serveur HTTP / WAF) → API Ingestion Logs PhishGuard → Normalisation JSON → Moteur de Règles + Détection Anomalies → Classification de l'Attaque → Création d'Incident + Sauvegarde Preuves → Alerte Dashboard

Attaques Couvertes dans le Prototype PhishGuard :

Catégorie d'Attaque	Signature / Motif de Détection	Niveau de Risque
SQL Injection (SQLi)	Présence de mots-clés SQL suspects dans les paramètres d'URL ou corps POST (UNION SELECT, OR 1=1, DROP TABLE, SLEEP()).	CRITICAL
Cross-Site Scripting (XSS)	Injection de balises HTML/JS dans les requêtes (<script>, onerror=, javascript:).	HIGH
Brute Force Auth	Répétition anormale de requêtes POST sur /login échouées depuis une même IP (> 5 tentatives / minute).	HIGH
Scanning / Reconnaissance	Recherche automatisée d'URI sensibles (/env, /admin, /wp-login.php, /phpmyadmin) générant de multiples erreurs 404.	MEDIUM
Path Traversal	Tentatives d'accès aux fichiers système via la séquence ../ (ex: /etc/passwd, c:\boot.ini).	HIGH
Comportement Bot / User-Agent	Utilisation de User-Agents suspects de scanners d'attaque connus (ex: sqlmap, nikto, nmap, python-requests sans identité).	MEDIUM
Anomalie de Trafic	Pic soudain de débit ou de requêtes réseau hors norme provenant d'un sous-réseau spécifique.	LOW - MEDIUM

7. Cas Fil Conducteur — Analyse et Qualification d'une Attaque

Exemple de Déroulement d'un Incidents Brute Force (INC-2026-001) :

- Réception des Événements :** L'API d'ingestion reçoit 15 requêtes HTTP POST consécutives dirigées vers POST /api/v1/auth/login en l'espace de 8 secondes depuis l'IP source 198.51.100.45.
- Analyse du Motif :** Le moteur d'analyse statistique détecte un taux d'échec de 100% avec le code HTTP 401 Unauthorized et un intervalle moyen entre requêtes de 530 ms.
- Classification :** L'attaque est automatiquement catégorisée sous l'étiquette **Brute Force / Authentification**.
- Attribution de Gravité :** Définie sur **HIGH** (Score de risque : 85/100).
- Création de l'Incident :** Enregistrement immédiat dans la base sous l'identifiant **INC-2026-001**.
- Scellement des Preuves :** Capture de l'IP source, User-Agent, horodatage exact, en-têtes HTTP et génération de l'empreinte Hash SHA-256: e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855.
- Alerte & Rapport :** Notification immédiate sur le Tableau de Bord de l'administrateur du site et mise à disposition du rapport téléchargeable.

8. Localisation de la Source & Limites Techniques (Plaidoirie Jury)

PhishGuard enrichit chaque adresse IP analysée avec des données de Threat Intelligence réseau (Pays, Ville approximative, ASN, Opérateur ISP).

Avertissement de Rigueur Scientifique et Juridique :

La géolocalisation IP représente une **localisation réseau apparente**. Elle ne constitue en aucun cas une preuve de la position géographique réelle ni de l'identité physique de l'attaquant. Les cybercriminels utilisent fréquemment des relais anonymiseurs (VPN, Proxies SOCKS, réseau Tor, serveurs Cloud compromis ou réseaux de machines zombies / Botnets) pour masquer l'origine réelle du trafic.

Déclaration de référence à soutenir devant le jury :

« Le système PhishGuard fournit des indicateurs techniques et une localisation apparente de la source réseau afin de faciliter l'investigation opérationnelle. L'identification de l'auteur réel nécessite impérativement des requêtes judiciaires et des vérifications complémentaires auprès des fournisseurs d'accès. »

9. Gestion des Incidents, Rapports & Portail de Vérification Enquêteur

PhishGuard intègre un mécanisme complet de chaîne de traçabilité des preuves numériques :

Analyse Originale (ANL-2026-000458) → Incident Qualifié (INC-2026-000127) → Génération du Rapport Officiel + Empreinte Hash SHA-256 → Soumission à l'Enquêteur → Saisie du Report ID dans le Portail Enquêteur → Extractions de l'Analyse Originale de la DB PhishGuard → Contrôle d'Intégrité par Hash → Validation / Rejet

Contenu Réglementaire du Rapport d'Incident :

- **Identifiants Uniques** : Report ID (ex: REP-2026-9941) et Analysis ID d'origine (ex: ANL-2026-000458).
- **Informations Déclarant** : Identité ou rôle de l'utilisateur ayant soumis l'élément, selon la politique de confidentialité.
- **Horodatage Précis** : Date et heure exactes de la détection au format ISO-8601 avec fuseau horaire (UTC).
- **Objet Analysé** : URL complète, extrait de message, structure de l'email ou logs HTTP ciblés.
- **Qualifications du Risque** : Type d'attaque identifiée, score de risque (0-100) et niveau de gravité (LOW, MEDIUM, HIGH, CRITICAL).
- **Preuves & Indicateurs** : Extraits de logs bruts, indicateurs réseau (IP, ASN, User-Agent) et résultats des contrôles externes.
- **Scellement d'Intégrité** : Empreinte Hash SHA-256 calculée sur l'ensemble des données d'analyse originales.
- **Statut de l'Enquête** : Statut du rapport dans le portail (*En attente, Validé, Rejeté, En cours d'investigation*).

10. Matrice des Rôles et Droits d'Accès (RBAC)

Rôle	Périmètre d'Autorisation et Actions Permises
Utilisateur Standard	• Lancer des analyses d'URLs, de messages et d'emails. • Enregistrer ses propres sites autorisés pour la surveillance. • Consulter l'historique de ses propres analyses et alertes. • Générer un rapport d'incident et le soumettre à la cellule d'enquête. • Interagir avec l'Assistant Cybersécurité IA.
Enquêteur / Agent	• Accéder au Portail Enquêteur sécurisé. • Rechercher tout rapport d'incident via son Report ID ou Code unique. • Extraire l'analyse originale scellée en base de données. • Effectuer la vérification d'intégrité cryptographique (Hash SHA-256). • Mettre à jour le statut de l'enquête (Validé, Classé sans suite, Transmis).
Administrateur	• Gestion complète des comptes utilisateurs et attribution des rôles. • Configuration des clés d'APIs externes (VirusTotal, OpenAI, GeoIP). • Monitoring de la santé des services, réentraînement du modèle ML. • Consultation des journaux d'audit technique (Audit Logs).

11. Architecture Technique et Stack Logicielle

Couche System	Technologie Sélectionnée	Rôle et Responsabilité Technique
Frontend UI	React 18 + Vite + Tailwind CSS	Interface web dynamique, tableaux de bord interactifs, formulaires d'analyse et affichage des graphiques.
Backend API	Python 3.11 + FastAPI	API REST asynchrone haute performance, authentification JWT, validation Pydantic et logique métier.
Engine ML	Scikit-Learn + Joblib + Pandas	Extraction des features, exécution du modèle Random Forest et calcul des scores de prédiction.
Base de Données	PostgreSQL (SQLite dev)	Stockage relationnel persistant des utilisateurs, analyses, événements, preuves, incidents et audit logs.
IA & Explications	API LLM (OpenAI / Claude / Gemini)	Génération de résumés d'explication du risque et alimentation du Chatbot défensif.
Threat Intelligence	VirusTotal API v3 + Safe Browsing	Vérification externe de la réputation des domaines, URLs et répertoires malveillants connus.
IP Intelligence	GeoIP2 / IP-API Service	Enrichissement des adresses IP source (Pays, Ville, ASN, Opérateur).
Conteneurisation	Docker & Docker Compose	Déploiement reproductible multi-services (Frontend, Backend, DB).

12. Modèle Logique de Données (MLD / Schema PostgreSQL)

Entités Principales de la Base de Données PhishGuard :

- **User** : id, email, password_hash, full_name, role_id, is_active, created_at
- **Role** : id, name (ADMIN, USER, INVESTIGATOR), description
- **Analysis** : id, user_id, type (URL, MESSAGE, EMAIL), target_input, overall_risk_score, risk_level, status, created_at
- **URLAnalysis** : id, analysis_id, domain, ip_address, has_ssl, url_length, num_dots, num_hyphens, has_at_symbol, is_whois_recent
- **MessageAnalysis** : id, analysis_id, sender_info, is_urgent_detected, extracted_urls_count, suspicion_score
- **MLPrediction** : id, analysis_id, model_version, confidence_score, predicted_label, feature_importance_json
- **RuleResult** : id, analysis_id, rule_code, rule_name, is_triggered, risk_impact
- **ExternalCheck** : id, analysis_id, service_name (VIRUSTOTAL, SAFE_BROWSING), verdict_positives, raw_response_json
- **Website** : id, owner_user_id, domain_name, api_key, is_monitored, created_at
- **SecurityEvent** : id, website_id, timestamp, source_ip, http_method, request_path, status_code, user_agent, raw_headers
- **Attack** : id, security_event_id, attack_type (SQLI, XSS, BRUTE_FORCE, SCANNING, PATH_TRAVERSAL), severity, confidence
- **Evidence** : id, attack_id, evidence_type, raw_payload, hash_sha256, captured_at
- **Incident** : id, website_id, incident_code (INC-2026-XXX), title, severity, status, created_at
- **IncidentReport** : id, incident_id, analysis_id, report_code (REP-2026-XXX), integrity_hash, report_pdf_path, created_at
- **ReportVerification** : id, report_id, investigator_user_id, is_integrity_valid, decision, verified_at
- **AuditLog** : id, user_id, action, target_entity, ip_address, timestamp

13. Exigences de Sécurité et Bonnes Pratiques

- **Chiffrement des Transmissions (HTTPS)** : Toutes les communications entre le client React et l'API FastAPI sont strictement chiffrées via TLS 1.3.

- **Protection des Mots de Passe** : Hachage sécurisé des mots de passe en base de données avec l'algorithme **Argon2id** ou **bcrypt** avec sel unique.
- **Authentification & Autorisation** : Authentification basée sur des jetons **JWT (JSON Web Tokens)** avec temps d'expiration court et contrôle d'accès strict (RBAC).
- **Sécurisation des Clés API Tiers** : Stockage exclusif des clés API externes (VirusTotal, LLM) dans les variables d'environnement du backend. Aucune clé dans le code client.
- **Validation Stricte des Entrées (Input Validation)** : Sanitization systématique de toutes les entrées utilisateur pour empêcher les injections SQL, XSS et Command Injection.
- **Limitation de Débit (Rate Limiting)** : Application de règles de Rate Limiting sur les endpoints FastAPI sensibles pour contrer les attaques par déni de service (DoS).
- **Traçabilité et Audit Trail** : Journalisation immuable de toutes les actions administratives et des accès au portail enquêteur dans la table AuditLog.

14. Assistant Cybersécurité Intelligente (Chatbot Défensif)

L'assistant conversationnel PhishGuard est directement **interconnecté au contexte d'analyse actif**.

Exemple de Scénario Opérationnel :

Si le système détecte une injection SQL sur un site surveillé, l'utilisateur peut interroger le chatbot : « *Pourquoi cette requête est-elle classée SQL Injection et comment sécuriser mon code PHP ?* ». Le chatbot analyse les événements scellés et fournit une réponse défensive contextualisée (ex: recommandation des requêtes préparées PDO / ORM).

Garde-fous Éthiques et Sécurité :

Le chatbot est strictement configuré pour fournir des **conseils exclusivement défensifs et de remédiation**. Tout prompt utilisateur tentant d'utiliser l'assistant pour générer des scripts d'attaque ou exploiter une vulnérabilité est automatiquement rejeté.

15. Structure des Interfaces Web (Sitemap UI)

TABLEAU DE BORD UTILISATEUR & ADMINISTRATEUR :

- **Vue d'Ensemble (Dashboard)** : Métriques clés, dernières détections, niveau de menace global.
- **Analyser une URL** : Formulaire de saisie, options d'analyse, restitution détaillée et score.
- **Analyser un Message / SMS** : Zone de texte, extraction automatique des liens, verdict sémantique.
- **Analyser un Email** : Dépôt de fichier .eml ou en-têtes, contrôle SPF/DKIM.
- **Mes Sites Surveillés** : Configuration des domaines autorisés, intégration des clés d'ingestion.
- **Alertes & Événements WAF** : Visualisation en temps réel du flux de requêtes HTTP et attaques.
- **Incidents & Rapports** : Liste des incidents (INC-2026-XXXX), génération de rapports PDF scellés.
- **Assistant Cybersécurité** : Interface conversationnelle d'aide à la décision.

PORTAIL ENQUÊTEUR (AGENT AUTORISÉ) :

- **Rapports Reçus** : Liste des dossiers d'incidents transmis pour investigation.
- **Rechercher un Rapport** : Moteur de recherche par Report ID / Code Hash.
- **Module de Vérification d'Intégrité** : Comparaison cryptographique avec l'analyse originale DB.
- **Validation & Suivi** : Mise à jour des statuts d'enquête et export des pièces juridiques.

16. Tableau Synthétique des Cas d'Utilisation (Use Cases)

Acteur	Code Use Case	Intitulé du Use Case	Objectif Métier
Utilisateur	UC-01	Analyser une URL	Obtenir un verdict immédiat et un score de risque sur une URL.
Utilisateur	UC-02	Analyser un Message/SMS	Détecter les tentatives de hameçonnage et urgence artificielle.
Utilisateur	UC-03	Surveiller un Site Web	Connecter les logs d'un site autorisé pour détecter les attaques.
Utilisateur	UC-04	Générer un Rapport	Créer un dossier scellé avec hash pour transmission légale.
Enquêteur	UC-05	Rechercher un Rapport	Retrouver un dossier via son Report ID ou son empreinte Hash.
Enquêteur	UC-06	Vérifier l'Intégrité	Comparer la copie transmise avec l'analyse originale en base DB.

Admin	UC-07	Gérer la Plateforme	Administrer les comptes, rôles, clés d'API et modèles ML.
-------	-------	---------------------	---

17. Pipeline d'Entraînement et d'Inférence ML

Dataset Étiqueté (Phishing vs Légitime) → Nettoyage & Normalisation → Extraction des Caractéristiques → Séparation Train (80%) / Test (20%) → Entraînement Random Forest → Évaluation Métriques → Sauvegarde Modèle (.pkl) → Déploiement Endpoint FastAPI (/predict)

Métriques de Validation Obtenues lors de la Phase de Test :

Métrique d'Évaluation	Formule Mathématique	Objectif Cible PhishGuard
Accuracy (Exactitude)	$(TP + TN) / (TP + TN + FP + FN)$	≥ 95.0%
Precision (Précision)	$TP / (TP + FP)$ (Limite les fausses alertes)	≥ 94.0%
Recall (Rappel)	$TP / (TP + FN)$ (Captures les vrais phishing)	≥ 93.0%
F1-Score	$2 * (Precision * Recall) / (Precision + Recall)$	≥ 94.0%

18. Diagramme du Pipeline Global du Système



19. Périmètre Fonctionnel à Développer (Livrables Logiciels)

- **Frontend Web React :** Interfaces d'analyse, tableaux de bord interactifs, portail enquêteur et composants d'alertes.
- **API Backend FastAPI :** Services Web RESTful asynchrones, contrôles d'accès RBAC, gestion des sessions JWT.
- **Base de Données PostgreSQL :** Modèle relationnel complet (tables, clés étrangères, indexations et déclencheurs).
- **Module d'Analyse URL & Feature Engineering :** Script d'extraction des 15+ variables et pipeline d'inférence ML.
- **Modèle ML Random Forest :** Script d'entraînement, jeux de données étiquetés, validation et sérialisation .pkl.
- **Module d'Analyse Messages/Emails :** Analyseur sémantique et parser de fichiers d'emails (.eml).
- **Module de Ingestion Logs Site Autorisé :** API de collecte d'événements HTTP et classificateur d'attaques WAF.

- **Module de Gestion des Incidents & Preuves** : Moteur de scellement cryptographique Hash SHA-256 et génération PDF.
- **Portail Enquêteur** : Module de contrôle d'intégrité et de comparaison des empreintes d'analyse.
- **Assistant Cybersécurité** : Chatbot IA intégré orienté conseils défensifs.

20. Matrice des Priorités MVP (P1 / P2 / P3)

Priorité	Fonctionnalité	Justification Stratégique MVP
P1 (Indispensable)	Analyse URL + Modèle ML Random Forest	Cœur névralgique de la détection de hameçonnage et valeur scientifique ML.
P1 (Indispensable)	Analyse Messages & Emails	Couverture complète des canaux d'ingénierie sociale.
P1 (Indispensable)	Threat Intelligence (APIs Externes)	Corroboration des prédictions internes par la réputation mondiale.
P1 (Indispensable)	Surveillance Logs Site & Détection Attaques	Démonstration de la protection applicative (SQLi, XSS, Brute Force).
P1 (Indispensable)	Incidents, Preuves & Portail Enquêteur	Prouve la traçabilité et l'immuabilité des preuves numériques.
P1 (Indispensable)	Assistant Cybersécurité Chatbot	Explication pédagogique et aide à la décision pour l'utilisateur.
P2 (Important)	Système de Notifications Alertes Temps Réel	Information instantanée en cas d'attaque critique détectée sur un site.
P2 (Important)	Statistiques Avancées & Tendances	Graphiques d'évolution temporelle des cybermenaces.
P3 (Évolution)	Anomalies ML Avancées (Deep Learning/Unsupervised)	Détection d'anomalies non supervisée après stabilisation du MVP.

21. Plan de Réalisation et Feuille de Route (12 Étapes)

- **Étape 1** : Validation définitive du cahier des charges, de l'architecture et des cas d'utilisation.
- **Étape 2** : Conception du schéma de base de données PostgreSQL, des spécifications d'API FastAPI et auth JWT.
- **Étape 3** : Développement du frontend React, de la charte graphique Tailwind et des dashboards de base.
- **Étape 4** : Collecte et préparation des jeux de données d'URLs, extraction de variables et entraînement ML.
- **Étape 5** : Intégration du moteur d'inférence ML Random Forest dans l'API backend PhishGuard.
- **Étape 6** : Implémentation du moteur de règles et interconnexion aux APIs Threat Intelligence (VirusTotal).
- **Étape 7** : Développement du module d'analyse sémantique des messages et d'analyse des fichiers d'emails.
- **Étape 8** : Création du module d'ingestion de logs et du générateur d'événements de test pour sites autorisés.
- **Étape 9** : Développement du classificateur d'attaques applicatives (SQLi, XSS, Brute Force, Scanning, Path Traversal).
- **Étape 10** : Implémentation de la chaîne d'incidents, scellement des preuves Hash SHA-256 et portail enquêteur.
- **Étape 11** : Intégration de l'Assistant Cybersécurité conversationnel basé sur l'IA explicative.
- **Étape 12** : Phase de recettes, tests d'intégration, audits de sécurité interne, documentation et préparation de la soutenance.

22. Scénario Complet de Démonstration (Soutenance devant le Jury)

Déroulement Chronologique Recommandé de la Démonstration (15-20 minutes) :

Acte 1 : Soumission d'une URL de Hameçonnage Suspecte

Saisie d'une URL contrefaite dans le formulaire. Le système exécute le modèle ML et les règles, interroge Threat Intel et affiche un verdict **HIGH RISK** avec le détail des caractéristiques suspectes et l'explication IA.

Acte 2 : Analyse d'un Message SMS Frauduleux

Copier-coller d'un SMS usurpant une banque avec urgence artificielle. PhishGuard isole le lien piège, analyse la sémantique et formule des recommandations défensives.

Acte 3 : Surveillance d'un Site Web Autorisé & Détection d'Attaque

Envoi d'une série de requêtes d'attaque (SQLi / Brute Force) vers le site de test surveillé. Le tableau de bord affiche instantanément la détection de l'attaque, la classification et la capture des preuves.

Acte 4 : Génération et Vérification d'un Rapport d'Enquête

Création d'un incident depuis l'attaque détectée et export du rapport scellé par Hash SHA-256. Basculement sur le **Portail Enquêteur** : l'agent recherche le rapport, le système compare l'empreinte avec la DB et confirme l'intégrité parfaite du dossier.

Acte 5 : Assistance Cybersécurité Conversationnelle

Interrogation du Chatbot IA sur les mesures de correction à apporter au site web suite à l'injection SQL détectée. Le chatbot fournit le code correctif sécurisé.

23. Guide des Réponses Stratégiques aux Questions du Jury

• Question : Pourquoi utiliser des APIs externes (VirusTotal) alors que vous avez un modèle ML ?

Réponse : Le modèle ML est notre propre intelligence prédictive (propriétaire) capable de détecter des menaces 0-day non encore répertoriées. Les APIs externes apportent une corroboration de réputation mondiale. La valeur de PhishGuard réside dans la fusion et la corrélation de ces sources d'information.

• Question : Une simple URL permet-elle de détecter toutes les attaques d'un site web ?

Réponse : Non, et c'est une distinction clé de notre architecture. L'analyse d'URL évalue la dangerosité d'un lien sortant. La surveillance de site requiert l'ingestion des événements/logs internes d'un environnement autorisé pour détecter des attaques applicatives (SQLi, XSS, Brute Force).

• Question : Comment garantissez-vous qu'un rapport soumis par un utilisateur n'a pas été falsifié ?

Réponse : L'enquêteur ne se fie pas au fichier fourni par l'utilisateur. Grâce au Report ID, le portail extrait directement l'analyse originale scellée en base de données et contrôle la correspondance exacte de l'empreinte Hash SHA-256.

• Question : La géolocalisation IP permet-elle d'arrêter l'attaquant ?

Réponse : Non. L'IP fournit une localisation réseau apparente utile pour l'investigation. L'identification physique de l'auteur nécessite des démarches judiciaires auprès des FAI car l'attaquant peut utiliser des VPN, Proxies ou le réseau Tor.

24. Ce qu'il ne Faut PAS Promettre (Périmètre Non Couvert)

- Ne JAMAIS prétendre localiser physiquement l'adresse exacte d'un pirate à partir de son IP.
- Ne JAMAIS garantir l'identification automatique de l'identité civile du criminel.
- Ne JAMAIS affirmer que le système peut détecter 100% de toutes les cyberattaques existantes.
- Ne JAMAIS présenter PhishGuard comme un remplacement total d'un WAF commercial, SIEM, Antivirus ou SOC complet.
- Ne JAMAIS prétendre qu'un modèle ML est infallible (toujours évoquer le taux de faux positifs/négatifs).
- Ne JAMAIS promettre le déclenchement automatique d'actions policières sans intervention humaine.

25. Checklist Finale de Recette et Validation

- Cahier des charges et architecture validés
- Modèle logique de données PostgreSQL déployé
- API FastAPI opérationnelle avec authentification JWT
- Jeu de données collecté et modèle ML Random Forest évalué
- Engine d'analyse URL avec extraction des 15+ features opérationnel
- Engine d'analyse des messages et emails opérationnel
- Intégration sécurisée de Threat Intelligence (VirusTotal)
- Ingestion de logs et détection d'attaques WAF (SQLi, XSS, Brute Force)
- Chaîne de gestion des incidents et scellement des preuves Hash SHA-256

- Portail de vérification enquêteur fonctionnel
- Assistant Cybersécurité conversationnel (Chatbot) intégré
- Cahier de recette, tests et dossier de démonstration finalisés

26. Conclusion et Synthèse du Projet

Le choix d'une **architecture Web full-stack** pour la plateforme **PhishGuard** est pleinement justifié. Il offre l'ergonomie, la puissance de traitement et la flexibilité nécessaires pour orchestrer l'ensemble des modules : détection d'analyse de contenu, surveillance d'événements applicatifs, scellement de preuves cryptographiques et portail d'investigation pour les enquêteurs.

Formule Synthétique à Retenir pour le Projet :

ENTRÉE → ANALYSE → ML / RÈGLES → THREAT INTELLIGENCE → CORRÉLATION → SCORE DE RISQUE → EXPLICATION IA → PREUVES → INCIDENT → RAPPORT → VÉRIFICATION ENQUÊTEUR → CONSEILS DÉFENSIFS